

AIPD allégée — traitement de localisation, GéoEmploi

Analyse d'impact relative à la protection des données, article 35 RGPD. Décrit le traitement tel qu'il fonctionne réellement dans le code au 2026-09-07 (branche `main`), pas une version prévue ni souhaitable.

Complète la fiche de registre déjà transmise (`RGPD_FICHE_TRAITEMENT.md`).

1. Description du traitement

Traitement analysé : géolocalisation du visiteur au clic sur le bouton « Offres près de moi » (`src/components/LocateMeButton.tsx`).

Finalité : proposer un tri des offres par distance à la position du visiteur.

Base légale : consentement (art. 6.1.a). Une notice précède tout appel à l'API de géolocalisation du navigateur, avec deux boutons de poids visuel égal, « Refuser » et « Autoriser ». Aucune case pré-cochée, aucun choix par défaut, aucune reconduction tacite : le choix est redemandé à chaque clic.

Personnes concernées : tout visiteur cliquant sur le bouton, avec ou sans compte.

Données traitées : latitude, longitude, précision en mètres.

Circulation de la donnée : la coordonnée est lue par le navigateur (`navigator.geolocation`), puis transmise du dialogue à la page qui porte la carte, où elle sert à afficher un repère et à centrer la vue. Elle vit en mémoire de la page et disparaît au rechargement ou à la fermeture de l'onglet. Elle n'est **jamais** transmise au serveur, jamais écrite en base, jamais posée en cookie ni en stockage local, jamais transmise à un tiers.

Durée de conservation : aucune conservation. Il n'existe aucune table d'historique de localisation dans le schéma de données.

Deuxième traitement de localisation, distinct : les offres d'emploi portent des coordonnées. Depuis le 2026-09-07, elles correspondent au centroïde officiel de la commune de l'offre, jamais à l'adresse exacte de l'employeur. Ces coordonnées décrivent un lieu de travail, non une personne physique.

2. Nécessité et proportionnalité

Nécessité : le tri par distance suppose de connaître un point de référence. La saisie manuelle d'une commune constitue une alternative fonctionnelle, et elle reste disponible : le refus de la géolocalisation ne bloque aucun parcours.

Proportionnalité — quatre éléments la soutiennent :

1. **Collecte déclenchée uniquement par un clic explicite.** Aucune géolocalisation passive, aucune collecte en arrière-plan, aucune collecte au chargement de la page.
2. **Aucune conservation.** La position n'est écrite nulle part : ni en base, ni en cookie, ni en stockage local. Elle vit en mémoire de la page et disparaît au rechargement. Le risque de fuite, de réutilisation ou de corrélation ultérieure est structurellement nul, faute de stockage.
3. **Aucune liaison à un compte.** Le bouton se comporte à l'identique connecté ou non ; la position n'est jamais rattachée à une identité.
4. **Maille communale pour les offres.** Depuis le retour à la version 1.0 du cahier des charges, la précision des offres est ramenée à la commune, ce qui réduit la finesse des données géographiques manipulées par le service.

Point de proportionnalité que nous signalons plutôt que de le taire : la position sert aujourd'hui à centrer la carte et à y afficher un repère, ce qui constitue un usage réel. Le **tri des offres par distance**, qui est la finalité annoncée à l'utilisateur dans la notice, n'est en revanche pas encore branché. La collecte dépasse donc encore légèrement la finalité pleinement opérante. La donnée n'étant ni conservée ni transmise, l'impact reste faible, mais l'écart doit être résorbé par le branchement du tri, et non prolongé.

3. Risques pour les personnes concernées

Cette section décrit ce que l'application fait aujourd'hui.

Risques traités

Risque	Mesure en place
Conservation d'un historique de déplacements	Aucune écriture en base ni en stockage navigateur. La position vit en mémoire de la page et disparaît au rechargement. Rien à conserver, rien à purger
Réidentification par croisement position / compte	La position n'est jamais associée à un identifiant de compte
Transmission à un tiers (analytics, régie, fournisseur de carte)	Aucun tiers ne reçoit la position. Le fond de carte IGN est chargé indépendamment du bouton
Consentement contraint ou pré-coché	Notice préalable, deux boutons de poids égal, choix redemandé à chaque usage
Perte d'accès au service en cas de refus	Le refus n'entraîne ni erreur ni écran vide : la consultation des offres reste entière
Exposition de l'adresse exacte d'un lieu de travail	Coordonnées ramenées au centroïde communal, en base et de façon irréversible

Risques non traités à ce jour

Deux risques restent ouverts. Nous les nommons avec leur raison, conformément à la demande.

Risque 1 — Absence de test automatisé garantissant que la position ne quitte pas le navigateur. La garantie centrale de ce traitement, « la position n'est jamais transmise au serveur », repose aujourd'hui sur la lecture du code et non sur un test qui échouerait si quelqu'un l'enfreignait. Une modification future pourrait introduire un envoi de la position sans qu'aucun garde-fou automatique ne le signale. *Raison du non-traitement* : le projet ne dispose d'aucune suite de tests automatisés à ce stade. Mettre en place un test dédié à ce seul point sans socle de test existant donnerait une assurance de façade. Le sujet relève de la mise en place d'une base de tests, prévue mais non engagée.

Risque 2 — Journalisation limitée aux actions, absente sur les consultations. Depuis le 2026-09-07, les actions de modération de l'espace d'administration (suspension d'un compte, changement de statut d'une offre) sont journalisées : chaque opération inscrit l'auteur, la cible et l'horodatage dans une table dédiée.

En revanche, la **consultation** des données n'est pas journalisée. Un administrateur qui ouvre la liste des comptes et lit les adresses e-mail des utilisateurs ne laisse aucune trace. En cas de consultation abusive sans modification, rien ne permettrait de la constater après coup. *Raison du non-traitement* : journaliser les lectures suppose de tracer chaque affichage de liste, ce qui produit un volume de journaux sans commune mesure avec celui des actions, et constitue en soi un traitement de données supplémentaire à encadrer. Ce choix demande un arbitrage entre traçabilité et minimisation que nous ne souhaitons pas trancher seuls, et que nous soumettons au service juridique.

4. Mesures de réduction retenues

Déjà en place

- Notice d'information affichée avant tout appel à l'API de géolocalisation, hors CGU
- Non-conservation de la position, par conception plutôt que par politique de purge
- Absence de liaison entre position et compte
- Maille communale pour les coordonnées d'offres, appliquée en base et irréversible
- Mots de passe hachés (bcrypt), jamais renvoyés par l'API
- Suppression en cascade des données rattachées à un compte, câblée dès la première migration
- Export des données personnelles sur demande (art. 20) : `GET /api/users/me/export`, authentifié, strictement scopé au compte appelant. Un compte neuf sans activité produit un export valide, testé. Les champs candidatures, historique de localisation et trace de consentement sont toujours présents et toujours vides, avec leur raison, plutôt que simplement absents

Engagées, à livrer

- Branchement effectif du tri par distance, pour que la collecte serve sa finalité
- Consultation permanente de la notice d'information depuis un espace de réglages
- Mécanisme de suppression de compte accessible à l'utilisateur

Écartées, avec leur raison

- *Purge automatisée des historiques de localisation* : sans objet. Il n'existe aucun historique à purger, la position n'étant jamais enregistrée. Créer une tâche de purge sur une table inexistante donnerait une apparence de conformité sans effet réel.
- *Anonymisation des positions* : sans objet pour la même raison.

5. Conclusion

Le traitement de localisation des visiteurs présente un niveau de risque faible, tenu principalement par l'absence de conservation : la donnée la plus sensible ne survit pas à la session d'affichage.

Les deux risques non traités portent sur la **vérifiabilité** des garanties (absence de test automatisé, absence de journalisation), non sur la collecte elle-même. Ils n'exposent pas de donnée aujourd'hui, mais ils privent le service des moyens de démontrer que ses garanties tiennent dans la durée.

Nous restons à disposition du service juridique pour toute précision, et pour réexaminer cette analyse dès que le tri par distance et l'espace d'administration seront opérants.